

Lernfeld 4 · IT-Grundschutz

Infoblätter: **IT-Grundschutz-Check & Risikoanalyse** sowie **Umsetzung & Verbesserung** – Ergänzung zur LF4-Zusammenfassung. Inhalte aus den Kursunterlagen (BSI-Standard 200-2 / 200-3).

Strukturanalyse ■ Schutzbedarf ■ Modell (Prüfplan) ■ Check ■ Umsetzung ■ Verbesserung

1 · IT-Grundschutz-Check (Soll-Ist-Vergleich)

Für jedes **Zielobjekt** wird geprüft, welche angemessenen technischen und organisatorischen Maßnahmen **bereits umgesetzt** sind und welche **noch fehlen**. Grundlage sind die zuvor bestimmten Zielobjekte und ihr Schutzbedarf nach dem IT-Grundschutz-Modell.

Was wird je Absicherungsvariante geprüft?

Basis-Absicherung	Nur die Basis-Anforderungen – schneller Einstieg für KMU.
Standard & Kern	Basis- und Standard-Anforderungen werden geprüft.
Erhöhter Schutzbedarf	Zusätzliche Maßnahmen aus der Risikoanalyse – nur, wenn sie Teil des Sicherheitskonzepts sind.

Umsetzungsstatus je Anforderung

Status	Bedeutung
Ja	Maßnahme vollständig festgestellt und umgesetzt.
Teilweise	Schutzmaßnahmen ergriffen, aber nicht vollständig.
Nein	Maßnahme erforderlich, aber noch nicht umgesetzt.
entbehrlich	Nicht erforderlich – ist auf jeden Fall zu begründen (auch wegen Datenschutz).

Vorbereitung & Dokumentation

- aktuelle Version des **IT-Grundschutz-Kompodiums**
- sicherheitsrelevante Dokumente (Abläufe, Regelungen, Sachverhalte)
- geeignete Ansprechpartner – **Vier-Augen-/Ohren-Prinzip** in entspanntem Klima
- Dokumentation je Zielobjekt: worauf bezogen, wann, durch wen, wer befragt – plus **Status**, **Nachweis/Beobachtung**, **Lücke/Maßnahme**, **Verantwortlicher**

2 · Risikoanalyse (BSI 200-3)

Der IT-Grundschutz deckt typische Gefährdungen ab. Eine **ergänzende Risikoanalyse** ist nötig, wenn der Standardansatz nicht ausreicht. Gefährdungen werden mit den betroffenen Grundwerten **C** (Vertraulichkeit), **I** (Integrität), **A** (Verfügbarkeit) angegeben.

Auslöser für eine Risikoanalyse

Auslöser	Beispiel
Hoher / sehr hoher Schutzbedarf	Active Directory oder Backup-System mit organisationsweiter Bedeutung.
Kein passender Baustein	Eigenentwicklung oder besondere Industrieanlage.
Untypische Einsatzumgebung	System läuft in Umgebung, für die der Standardbaustein nicht reicht.
Zusätzliche Gefährdungen	Neue Bedrohungslage, kritische Schnittstellen, Dienstleisterabhängigkeit.
Offene zentrale Anforderung	Eine MUSS-Anforderung ist offen – das Restrisiko muss bewertet werden.

Bewertung: Häufigkeit · Schaden · Risikoklasse

Häufigkeit	selten (seltener als alle 5 J.) · mittel (5 J. bis jährl.) · häufig (jähr. bis monatl.) · sehr häufig (mehrmals/Monat)
Schadenshöhe	vernachlässigbar · begrenzt · beträchtlich · existenzbedrohend
Risikoklasse	gering · mittel · hoch · sehr hoch (aus Häufigkeit × Schaden = Risikomatrix)

Risiken behandeln – 4 Optionen

Option	Erklärung	Beispiel
Risikovermeidung	Prozess/Nutzung beenden oder ändern.	Unsichere Altanwendung abschalten.
Risikoreduktion	Maßnahmen senken Wahrscheinlichkeit/Schaden.	MFA, Patchmanagement, Segmentierung.
Risikotransfer	Folgen teilweise übertragen.	Versicherung, Betrieb durch Dienstleister.
Risikoakzeptanz	Restrisiko bewusst tragen.	Nur mit Begründung & Leitungsentscheidung.

Abschluss: **Konsolidierung** – Maßnahmen auf Eignung, Angemessenheit, Benutzerfreundlichkeit und ihr Zusammenwirken prüfen.

3 · Umsetzung & Realisierungsplan

Ohne Realisierungsplan bleibt Informationssicherheit eine Sammlung guter Absichten. Offene Anforderungen werden in einen konkreten, nachverfolgbaren Plan überführt.

Maßnahmen konsolidieren – Prüffragen

- Ist die Maßnahme **erforderlich**? (Doppelte/unnötige vermeiden)
- Deckt sie die festgestellte **Lücke** ab?
- Technisch und organisatorisch **umsetzbar**?
- **Wirkt sie zusammen** mit anderen Maßnahmen?
- **Wirtschaftlich** angemessen zum Schutzbedarf?
- Nachvollziehbar **dokumentiert**?

Aufwand schätzen

Personalaufwand	interne Arbeitszeit, externe Beratung, Schulungen, Projektleitung
Sachmittel	Hardware, Software, Lizenzen, Cloud-Dienste, Prüfwerkzeuge
Finanzmittel	Anschaffung, Betrieb, Wartung, Support
Abhängigkeiten	vorherige Maßnahmen, Systemwechsel, Dienstleister, Change-Fenster
Dringlichkeit	Schutzbedarf, Risikostufe, offene MUSS-Anforderung, gesetzliche Vorgabe

Priorität R1 / R2 / R3

Prio	Bedeutung	Typisches Beispiel
R1 / kurzfristig	Dringend – hohes Risiko oder zentrale Lücke.	MFA für Admin-Konten; Restore-Test nach Ransomware-Risiko.
R2 / mittelfristig	Wichtig, aber nicht akut kritisch.	Dokumentation verbessern, Prozess formal freigeben.
R3 / langfristig	Sinnvoll, kann später umgesetzt werden.	Optimierung, Automatisierung, Komfort.

Reihenfolge: erst **Basis**-, dann **Standard**-, dann **erhöhte** Anforderungen. Risiken aus offenen Basis-Anforderungen **sollten nicht akzeptiert** werden – sie sind das Mindestniveau.

Realisierungsplan – Spalten

Maßnahme · Zielobjekt · Quelle · Priorität · Verantwortlich · Aufwand · Termin · Nachweis/Status – so konkret, dass die Umsetzung verfolgt, geprüft und der Leitung berichtet werden kann.

Umsetzung steuern & nachweisen

- Status pflegen: **offen · in Arbeit · umgesetzt · geprüft · zurückgestellt**
- Nachweise sammeln: Protokolle, Screenshots, Richtlinien, Tickets, Freigaben
- Abweichungen begründen (warum geändert/verschoben?)
- **Restrisiken der Leitung vorlegen** – Akzeptanz ist Managemententscheidung
- Ergebnisse ins **Sicherheitskonzept zurückführen**

4 · Aufrechterhaltung & Verbesserung

Informationssicherheit ist **kein einmaliges Projekt**. Verfahren mind. **einmal jährlich** (max. alle 3 Jahre) überprüfen.

Prüfinstrumente

Instrument	Zweck
IS-Revision	Prüft, ob Vorgaben, Prozesse und Maßnahmen wirksam umgesetzt sind (ISMS & Grundschutz).
Cybersicherheits-Check	Pragmatische Einschätzung der Angriffs-Anfälligkeit; Standortbestimmung.
Penetrationstest	Technischer Test mit simulierten Angriffen (Webanwendungen, Netze, Dienste).
Audit	Formalisierte Prüfung nach festen Kriterien (Zertifizierung, interne Kontrolle).
Managementbewertung	Leitung bewertet Wirksamkeit, Ressourcen, Risiken, Verbesserungsbedarf.

Kennzahlen als Güte-Indikator

Kennzahl	Berechnung
Patchquote	$\text{aktuelle Systeme} / \text{alle Systeme} \times 100$
MFA-Abdeckung	$\text{MFA-geschützte Admin-Konten} / \text{alle Admin-Konten} \times 100$
Backup-Erfolgsquote	$\text{erfolgreiche Backups} / \text{geplante Backups} \times 100$
Restore-Test-Quote	$\text{durchgeführte} / \text{geplante Restore-Tests} \times 100$
Schulungsquote	$\text{geschulte} / \text{relevante Mitarbeitende} \times 100$
Offene Lücken	Anzahl überfälliger R1/R2-Maßnahmen

Kennzahlen ersetzen keine fachliche Bewertung – sie machen Entwicklungen sichtbar.

Reifegradmodell (0–5)

Stufe	Kennzeichen
0	Kein Prozess, keine Planung.
1	Planungen vorhanden, aber keine Umsetzung.
2	Teile umgesetzt, kaum systematische Dokumentation.
3	Prozess vollständig umgesetzt und dokumentiert.
4	Wird zusätzlich regelmäßig auf Wirksamkeit geprüft.
5	Zusätzlich kontinuierliche Verbesserung etabliert.

Zertifizierung: ISO 27001 auf Basis von IT-Grundschutz. Zertifikat **3 Jahre** gültig, mit jährlichem Überwachungsaudit (Dokumenten- + Umsetzungsprüfung, Auditbericht).

5 · Angriffsmethoden im Überblick

Nicht jede Bedrohung ist Schadcode – auch fehlende Prozesse, schwache Organisation und physische Risiken zählen. Kernabgrenzung: die **Schwachstelle** ist die offene Tür, der **Exploit** der Hebel, der sie öffnet, die **Payload** die Schadfunktion danach.

Initialzugang ■ Ausführung ■ Persistenz ■ Rechteausweitung ■ laterale Bewegung ■ Exfiltration ■
Auswirkung

Grundlagen & Angriffskette (8)

Methode	Erklärung
Schwachstelle	Ein Fehler oder eine Fehlkonfiguration, die missbraucht werden kann.
Exploit	Code/Methode, der eine Schwachstelle gezielt ausnutzt – der Hebel, der die Tür öffnet.
Payload	Die Schadfunktion nach erfolgreicher Ausnutzung – das eigentliche Ziel des Angreifers.
Initialzugang	Der erste Einstieg ins System (z. B. Phishing-Mail, gestohlene Zugangsdaten).
Persistenz	Mechanismen, um nach Neustart/Logout wieder ins System zu kommen (z. B. Autostart).
Privilegienausweitung	Von normalen Rechten zu Admin-/Root-Rechten gelangen.
Laterale Bewegung	Ausbreitung von einem System/Konto zum nächsten im Netzwerk.
Exfiltration	Das Abziehen von Daten aus dem Zielsystem.

Schadsoftware (Malware) (13)

Methode	Erklärung
Malware	Oberbegriff für Software, die Systeme schädigt, ausspäht, missbraucht oder unbefugt kontrolliert.
Virus	Schadcode, der sich an Dateien/Programme heftet und sich durch deren Ausführung verbreitet.
Wurm	Schadcode, der sich selbstständig über Netzwerke oder Schwachstellen verbreitet.
Trojaner	Tarnt sich als legitime Software; dient oft als Türöffner für weitere Schadfunktionen.
Ransomware	Verschlüsselt/blockiert Systeme und fordert Lösegeld für die Freigabe.
Spyware	Überwacht Aktivitäten im Hintergrund und überträgt Informationen.
Keylogger	Zeichnet Tastatureingaben auf (Soft- oder Hardware) und stiehlt Passwörter.
Rootkit	Versteckt Prozesse/Dateien auf Admin-/Kernel-Ebene und erschwert die Erkennung.
Bot / Botnet	Macht Systeme fernsteuerbar über eine Command-and-Control-Infrastruktur (C2), z. B. für DDoS.
Scareware	Täuscht Warnmeldungen vor, um zu Zahlungen oder Installationen zu drängen.
Adware / Malvertising	Unerwünschte Werbung, die trackt oder über Anzeigen Malware nachlädt.
APT	Advanced Persistent Threat: langanhaltender, zielgerichteter Angriff, oft staatlich unterstützt.
RCE	Remote Code Execution: Ausführung von beliebigem Code auf einem entfernten System.

Social Engineering (19)

Methode	Erklärung
Social Engineering	Ausnutzen der „Schwachstelle Mensch“ über Vertrauen, Autorität, Zeitdruck oder Angst.
Phishing	Gefälschte Kommunikation zum Abgreifen von Zugangsdaten oder zur Malware-Installation.
Spear-Phishing	Gezieltes Phishing gegen bestimmte Personen/Teams mit personalisierten Inhalten.
CEO-Fraud / Whaling	Manipulation von Zahlungen durch vorgetäuschte Chef-Anweisung (zunehmend mit KI-Stimmklon).
Smishing	Phishing über SMS oder Messenger.
Vishing	Phishing über Telefon/Voice (z. B. Fake-Support-Anruf).
Angler-Phishing	Gefälschter Marken-Kundenservice in sozialen Netzwerken.
QRishing	Phishing über manipulierte QR-Codes (Plakate, Briefe, Aushänge).
Typosquatting	Domains mit Tippfehlern, die echten ähneln (z. B. „micros0ft“).
Combosquatting	Bekannte Marke plus Zusatz (z. B. „paypal-secure-login“).
Pretexting	Erfinden einer glaubwürdigen Geschichte als Vorwand.
Baiting / USB-Drop	Auslegen präparierter Datenträger, die Neugier ausnutzen.
Tailgating	Unbefugter Zutritt durch Mitgehen hinter einer berechtigten Person.
Shoulder Surfing	Ausspähen von Bildschirmen oder PINs im öffentlichen Raum.
Doxing	Zusammentragen und böswilliges Veröffentlichen privater Daten.
MFA-Fatigue	Überflutung mit Login-Bestätigungen, bis das Opfer versehentlich zustimmt.
Brute Force	Automatisiertes Durchprobieren aller möglichen Passwörter.
Credential Stuffing	Geleakte Zugangsdaten werden bei anderen Diensten ausprobiert.
Password Spraying	Wenige häufige Passwörter gegen viele Konten testen (umgeht Sperren).

Cyberphysisch & Netz (7)

Methode	Erklärung
Man-in-the-Middle	Angreifer sitzt zwischen zwei Partnern und liest mit oder manipuliert.
Sniffing	Passives Mitschneiden von Netzwerkverkehr.
ARP-Spoofing	Manipulation im LAN, um Verkehr über das Angreifersystem umzuleiten (Fake-Gateway).
DNS-Spoofing / Pharming	Manipulierte DNS-Antworten leiten trotz korrekter Adresse auf falsche Ziele.
Evil Twin	Gefälschter WLAN-Access-Point mit vertrautem Namen greift Logins/Verkehr ab.
Replay-Angriff	Aufgezeichnete Authentifizierungsdaten werden erneut gesendet.
DoS / DDoS	Überlastung eines Dienstes; DDoS verteilt aus vielen Quellen (Botnetz).

Web-Angriffe (6)

Methode	Erklärung
Cross-Site Scripting (XSS)	Einschleusen von böartigem JavaScript in Webseiten.
CSRF	Cross-Site Request Forgery: unerwünschte Aktion im Namen eines angemeldeten Nutzers.
SSRF	Server-Side Request Forgery: der Server wird zu internen/unerwünschten Aufrufen verleitet.

Methode	Erklärung
Broken Access Control	Fehlerhafte Zugriffskontrolle erlaubt Zugriff auf fremde Daten/Funktionen.
Session Hijacking	Übernahme einer Sitzung über gestohlene Cookies/Tokens.
SQL Injection	Einschleusen von SQL-Befehlen über Eingabefelder zum Auslesen/Manipulieren der DB.

Datenbank-Angriffe (2)

Methode	Erklärung
Exfiltration über legitime Schnittstellen	Missbrauch regulärer Export-, Backup- oder Reporting-Funktionen zum Datenklau.
DB-Fehlkonfiguration	Offene DB-Ports, aktive Standardkonten oder unverschlüsselte Verbindungen.

KI-Bedrohungen (6)

Methode	Erklärung
Data Poisoning	Gezieltes Vergiften der Trainingsdaten vor dem Training.
Adversarial Examples	Präparierte Eingaben, die für Menschen normal wirken, das Modell aber täuschen.
Prompt Injection	Eingeschleuste Anweisungen, die ein Sprachmodell seine Vorgaben ignorieren lassen.
Datenleck in Trainingsdaten	Ungewollte Preisgabe vertraulicher Infos aus Modell oder Logs.
Deepfake	Täuschend echte KI-Fälschung von Audio/Video für Betrug oder Desinformation.
KI als Angriffsverstärker	KI beschleunigt und skaliert bestehende Angriffe (Massen-Phishing, Personalisierung).

Warnsignal Social Engineering: künstlicher Druck – „sofort“, „vertraulich“, „Chef-Anweisung“, „Konto wird gesperrt“.